

ADLYTIC Audit Comparison — V1 vs V2

V1 baseline: ADLYTIC_MASTER_ARCHITECT_AUDIT_2026.md (commit 05752ef, dated 2026-06-29) V2 audit: ADLYTIC_MASTER_ARCHITECT_AUDIT_2026_V2.md (branch feat/horizontal-scaling, commit 32cd337, dated 2026-06-30) Branch delta: 4 commits, +2,664 / " 176 lines across 18 files (64f080e ... 32cd337)

Summary Counts

Status | R1–R15 | Pillar findings (P*~*) | New V2-only items

Fixed | 0 | 0 | 1 (P1-10 hijack guard)
Partially fixed | 2 (R1, R6) | 2 (P1-06, P3-06) | 4 (P1-09, P2-10, P2-11, P3-13)
Not fixed | 13 | 38 | —
Regressed | 0 | 1 (P1-01 line count) | —

Pillar counts include strengths marked "Preserved" as Not fixed (intentional non-regression). New V2-only items are additions, not V1 regressions.

R1–R15 Recommendation Tracker

Finding (V1) | Status in V2 | Evidence

R1 — Fix advisory lock strategy (sync()) / auto-sync | Partially fixed | syncChunked retains pg_advisory_unlock_all() preflight (syncAccount.ts:1061-1067). sync() still uses bare pg_try_advisory_lock (syncAccount.ts:193-195). Auto-sync in serve.ts:204 still calls worker.sync(), not syncChunked or queue. No dedicated lock-holding client.
R2 — Persist OAuth post-callback session | Not fixed | oauthSessions Map at server.ts:189; read/write at connect routes 2359+, 2666+, 2765+. No DB/Redis session model added.
R3 — Indexes (tokenSource, status, tokenExpiresAt), (status, lastSyncedAt) | Not fixed | prisma/schema.prisma AdAccount indexes unchanged (@@index([workspaceId]), @@index([connectionId]) only). No migration after 05752ef.
R4 — Configure pg.Pool max + timeouts | Not fixed | serve.ts:69-76 — new pg.Pool({ host, port, ... }) without max or idleTimeoutMillis.
R5 — ALLOWED_ORIGINS + config.ts fail-fast | Not fixed | server.ts:270 reads process.env['ALLOWED_ORIGINS'] directly; config.ts has no CORS section; no production fatal for empty origins.
R6 — Extract sync/engine work to job queue | Partially fixed | BullMQ added: lib/queue.ts, 4 processors, enqueueOrFallback at webhook/sync/kickoff sites. BULLMQ_ENABLED defaults false (config.ts:248). Workers co-located in API process (serve.ts:96, workers/queue/index.ts:7-11). Auto-sync loop not queued (serve.ts:118-225).
R7 — Chunk \$transaction in DailyStatsRepo.upsertMany | Not fixed | dailyStatsRepo.ts:68-94 — single \$transaction over all rows unchanged.
R8 — Split server.ts into route modules | Not fixed | File grew 3,392 !' 3,486 lines. Only kickoffInitialSync extracted to lib/initialSync.ts.
R9 — Centralize Meta error code helpers | Not fixed | 190 detection still regex in serve.ts:210 and typed in syncAccountProcessor.ts:114-116. No isMetaErrorCode in metaClient.ts.
R10 — Align getAccount() with primary account selection | Not fixed | server.ts:467 — ws.adAccounts[0] ?? null without orderBy.
R11 — Reduce any usage (31 hits) | Not fixed | `rg` : any | as any` src` !' 31 occurrences (unchanged).
R12 — Deduplicate dashboard pollSyncJob | Not fixed | Local pollSyncJob in dashboardPage.ts:1800-1811; window.pollSyncJob exported at layout.ts:1168.
R13 — TLS verify-full for DATABASE_URL | Not fixed | serve.ts:68, getDashboard.ts:66 — ssl: { rejectUnauthorized: false }.
R14 — Integration tests (webhooks, SyncJob, locks, OAuth) | Not fixed | Added scripts/test-redis-scaling-drill.ts (Redis ops drill, not app integration tests). No new test files for HMAC, SyncJob lifecycle, or advisory locks.
R15 — Vendor Chart.js / self-host CDN | Not fixed | CSP still allows cdn.jsdelivr.net (server.ts:299-300). No UI file changes in branch delta.

Pillar 1 — Architecture & Code Quality

Finding (V1) | Status in V2 | Evidence

P1-01 — Monolithic server.ts (~3,392 lines) | Regressed | 3,486 lines (wc -l src/api/server.ts). Net +94 despite partial extraction.
P1-02 — Duplicate pollSyncJob in dashboard onboarding | Not fixed | dashboardPage.ts:1800-1811 local function; not calling window.pollSyncJob.
P1-03 — getAccount() first account arbitrary | Not fixed | server.ts:467 — adAccounts[0].
P1-04 — 31× any usage | Not fixed | Count unchanged at 31.
P1-05 — Unhandled rejection log-only | Not fixed | serve.ts:42-48; BullMQ workers log errors without process exit (workers/queue/index.ts:96-102).
P1-06 — process.env outside config.ts | Partially fixed | config.ts now owns REDIS_URL, BULLMQ_ENABLED, WEBHOOK_REDIS_DEBOUNCE_ENABLED. ALLOWED_ORIGINS, Stripe, Anthropic, dashboard timeout still direct env reads.

P1-07 — Standalone Prisma pool in getDashboard.ts | Not fixed | Module-level _pool at getDashboard.ts:60-68.
P1-08 — Layer discipline (strength) | Preserved | Meta/DTO/engine separation intact; initialSync.ts extraction aligns with layering.
P1-09 — *(V2 new)* Default-off horizontal-scaling flags | New | config.ts:230-255 — infrastructure present, production default = V1 behavior.
P1-10 — *(V2 new)* Cross-workspace AdAccount hijack guard | Fixed | findExistingAdAccountForWorkspace + 409 at server.ts:404-427, 2725, 2848, 3048 (e6ef331).

Pillar 2 — Concurrency, Locking & Data Integrity

Finding (V1) | Status in V2 | Evidence

P2-01 — Session advisory locks + pool (Critical) | Partially fixed | syncChunked mitigation unchanged. sync() + auto-sync path still lack preflight.
P2-02 — 32-bit lock hash collision | Not fixed | advisoryLock.ts:16-22 unchanged.
P2-03 — SyncJob dedupe (strength) | Preserved | Fix A logic unchanged in sync API routes.
P2-04 — Unbounded \$transaction in upsertMany | Not fixed | dailyStatsRepo.ts:68-94.
P2-05 — Campaign reconcile transaction size | Not fixed | syncAccount.ts reconcile path unchanged.
P2-06 — No deadlock retry | Not fixed | No 40P01 handler added.
P2-07 — Crash lock release caveat | Not fixed | Comments/behavior unchanged.
P2-08 — Coarse auto-sync lock duration | Not fixed | serve.ts:231-241 unchanged.
P2-09 — Idempotent upserts (strength) | Preserved | Schema unique keys unchanged.
P2-10 — *(V2 new)* BullMQ co-located with API | New (risk when enabled) | Up to 12 concurrent jobs, same Prisma pool (workers/queue/index.ts:32-37).
P2-11 — *(V2 new)* reconcile-campaigns queue unused | New (incomplete) | Processor boots; no reconcileCampaigns.add producer (reconcileCampaignsProcessor.ts:6-10).

Pillar 3 — Meta API Resilience & Webhooks

Finding (V1) | Status in V2 | Evidence

P3-01 — Retry policy gaps | Not fixed | metaClient.ts unchanged.
P3-02 — Code 17 handling (strength) | Preserved | withCode17Retry unchanged.
P3-03 — Pagination cap 500 | Not fixed | metaClient.ts:195-208 unchanged.
P3-04 — Token lifecycle (no index on expiry) | Not fixed | Refresh worker query unchanged; index gap remains (see P5-10).
P3-05 — Webhook HMAC (strength) | Preserved | metaWebhook.ts:59-70, server.ts route unchanged.
P3-06 — Webhook idempotency (debounce only) | Partially fixed | Redis SET NX EX path when WEBHOOK_REDIS_DEBOUNCE_ENABLED=true (metaWebhook.ts:173-196). Still no delivery-id dedupe. Reconcile fire still setTimeout. Flag defaults off.
P3-07 — Webhook GET handshake | Not fixed | Unchanged.
P3-08 — Stripe webhook (strength) | Preserved | Unchanged.
P3-09 — 190 parsing inconsistency | Not fixed | Regex vs typed checks persist across serve.ts and queue processor.
P3-10 — Breakdown #100 skip (strength) | Preserved | Unchanged.
P3-11 — OAuth session in-memory (High) | Not fixed | oauthSessions Map persists.
P3-12 — META_APP_SECRET optional at boot | Not fixed | Fail-closed at request time only.
P3-13 — *(V2 new)* Token-health cache stale after reconnect | New gap | invalidateCachedTokenHealth defined (cachedTokenHealth.ts:90) but never called from connect/regrant paths.

Pillar 4 — UI/UX Robustness

Finding (V1) | Status in V2 | Evidence

P4-01 — Centralized pollSyncJob (strength) | Preserved | layout.ts:729-741; no changes in 05752ef..HEAD UI diff.
P4-02 — runWorkspaceSync + resume (strength) | Preserved | Unchanged.
P4-03 — Dashboard duplicate poll | Not fixed | dashboardPage.ts:1800-1811.
P4-04 — RUNNING/IN_PROGRESS enum mismatch | Not fixed | layout.ts:892, dashboardPage.ts:1788.
P4-05 — Null-safe rendering (strength) | Preserved | Unchanged.
P4-06 — Token decrypt banner (strength) | Preserved | Now uses cached backend (server.ts:1328).
P4-07 — Token health primary account only | Not fixed | checkWorkspaceTokenHealth.ts:38-52 unchanged.
P4-08 — Thumbnail fallback (strength) | Preserved | Unchanged.
P4-09 — Video thumbnail gap | Not fixed | Unchanged.
P4-10 — friendlyApiError (strength) | Preserved | Unchanged.
P4-11 — Dashboard refresh visibility pause | Not fixed | Unchanged (low severity).
P4-12 — Chart.js CDN dependency | Not fixed | Unchanged.

Pillar 5 — Security & Performance

Finding (V1) | Status in V2 | Evidence

P5-01 — JWT + tokenVersion (strength) | Preserved | Unchanged.
P5-02 — CORS permissive when origins empty | Not fixed | server.ts:270-279.
P5-03 — CSP unsafe-inline | Not fixed | Unchanged.
P5-04 — TLS verify disabled for DB | Not fixed | serve.ts:68, getDashboard.ts:66.
P5-05 — In-memory rate limits | Not fixed | server.ts:145-163; comment "Single-instance".
P5-06 — Platform admin env emails | Not fixed | adminGuard.ts:40.
P5-07 — Token encryption (strength) | Preserved | Unchanged.
P5-08 — AI sanitization | Not fixed | No line-by-line proof added.
P5-09 — Missing index lastSyncedAt | Not fixed | No schema change.
P5-10 — Missing index tokenExpiresAt | Not fixed | No schema change.
P5-11 — Webhook external ID lookup | OK | Unique constraint sufficient.
P5-12 — SyncJob index (strength) | Preserved | @@index([adAccountId, status]).
P5-13 — Raw insights bloat | Not fixed | Prune logic unchanged; no partial index.
P5-14 — Pool default max 10 | Not fixed | Unconfigured; worse when BullMQ concurrency=12.
P5-15 — Dashboard stage timeout (strength) | Preserved | Unchanged.
P5-16 — Timer / OAuth prune memory | Not fixed | Unchanged.
P5-17 — Platform stats cache per-instance | Not fixed | Unchanged.
P5-18 — *(V2 new)* Dual Redis connections | New | App singleton + BullMQ dedicated client when queue enabled.

Executive Verdict Comparison

Dimension | V1 | V2

Shippable single-instance beta | Yes | Yes
Multi-replica ready | No | No (foundation only; defaults = V1)
Top risk #1 | Advisory locks + pool on auto-sync | Same — sync() path untouched
Top risk #2 | Single-process background coupling | Mitigated optionally — BullMQ when flagged; auto-sync still in-process
Top risk #3 | In-memory OAuth / rate limits | Same — OAuth sessions unchanged
Scale readiness grade | D+ | C" (infrastructure added, gaps remain)
New security fix | — | Cross-workspace connect hijack !' 409

What Was NOT Fixed

(Factual gaps remaining after V2 — no recommendations.)

Critical / High (from V1, still open)

- sync() advisory lock preflight missing — auto-sync in serve.ts:204 calls worker.sync() without pg_advisory_unlock_all() mitigation present in syncChunked.
- OAuth post-callback sessions in-memory — oauthSessions Map at server.ts:189; lost on redeploy / wrong replica without sticky sessions.
- Missing DB indexes — AdAccount.lastSyncedAt and AdAccount.tokenExpiresAt (composite with tokenSource, status) have no migrations.
- pg.Pool max/timeouts not configured — default max 10; BullMQ can run 12 concurrent jobs when enabled.
- CORS ALLOWED_ORIGINS not in config.ts — no production fail-fast for empty origins.
- TLS rejectUnauthorized: false on external DATABASE_URL hosts.
- getAccount() uses adAccounts[0] without deterministic ordering or primary flag.
- Standalone second Prisma pool in getDashboard.ts at import time.
- Unbounded \$transaction in DailyStatsRepo.upsertMany.

Medium / structural (from V1, still open)

- Monolithic server.ts (now larger: 3,486 lines).
- In-memory rate limiting (server.ts:145).
- Meta 190 error detection not centralized (regex vs typed paths).
- No deadlock retry on Prisma 40P01.
- process.env reads for Stripe, Anthropic, PUBLIC_APP_URL, DASHBOARD_STAGE_TIMEOUT_MS.
- 31× TypeScript any / as any.
- Dashboard onboarding duplicate pollSyncJob.

- UI status enum checks for non-existent RUNNING / IN_PROGRESS.
- Chart.js CDN dependency.
- Raw insights table growth between prunes (no partial index on fetchedAt).
- Platform stats in-memory cache per instance.
- No integration tests for advisory locks, webhook HMAC, SyncJob lifecycle, OAuth DB roundtrip.

Horizontal-scaling branch items incomplete at V2

- BULLMQ_ENABLED defaults false — queue infrastructure inactive unless explicitly enabled.
- WEBHOOK_REDIS_DEBOUNCE_ENABLED defaults false — cluster debounce inactive unless enabled.
- Auto-sync not routed through BullMQ — remains synchronous loop in serve.ts.
- BullMQ workers co-located with HTTP — Phase 3-b separate dyno not implemented.
- reconcile-campaigns-v1 queue has consumer but no producer — webhook reconcile still uses setTimeout.
- Redis debounce winner still fires via in-process timer — reconcile lost if winning process dies before timer (metaWebhook.ts:165-170).
- invalidateCachedTokenHealth never invoked — reconnect paths do not bust token-health cache.
- R1–R5 from V1 prioritized list — none fully closed.

Fixed in V2 (for completeness)

- Cross-workspace Meta ad account silent hijack on reconnect !' explicit 409 AD_ACCOUNT_ALREADY_LINKED_ELSEWHERE at three connect sites (e6ef331).

End of ADLYTIC_AUDIT_COMPARISON_V1_V2.md

